SAÉ 4.CYBER.01

PLATEFORME INTELLIGENTE D'AUDIT DE SÉCURITÉ WEB

SOLUTION AUTOMATISÉE DE DÉTECTION DES VULNÉRABILITÉS

MOHAMMED– EMEER – HAZEEM – WARID - RAYAN- FADLAN

SOMMAIRE

01 Présentation du projet

- Contexte
- Objectif du projet

02 Conception de la plateforme

- Architecture de la plateforme
- Démarche de réalisation

03 Outils & fonctionnement

- Outils utilisés
- Fonctionnement de la plateforme

04 Résultats & analyse

- STRUCTURE DU RAPPORT D’AUDIT
- EXEMPLE DE RAPPORT
- Système de scoring
- Points forts & limites
- Exemple d’audit

PRÉSENTATION DU PROJET

Contexte

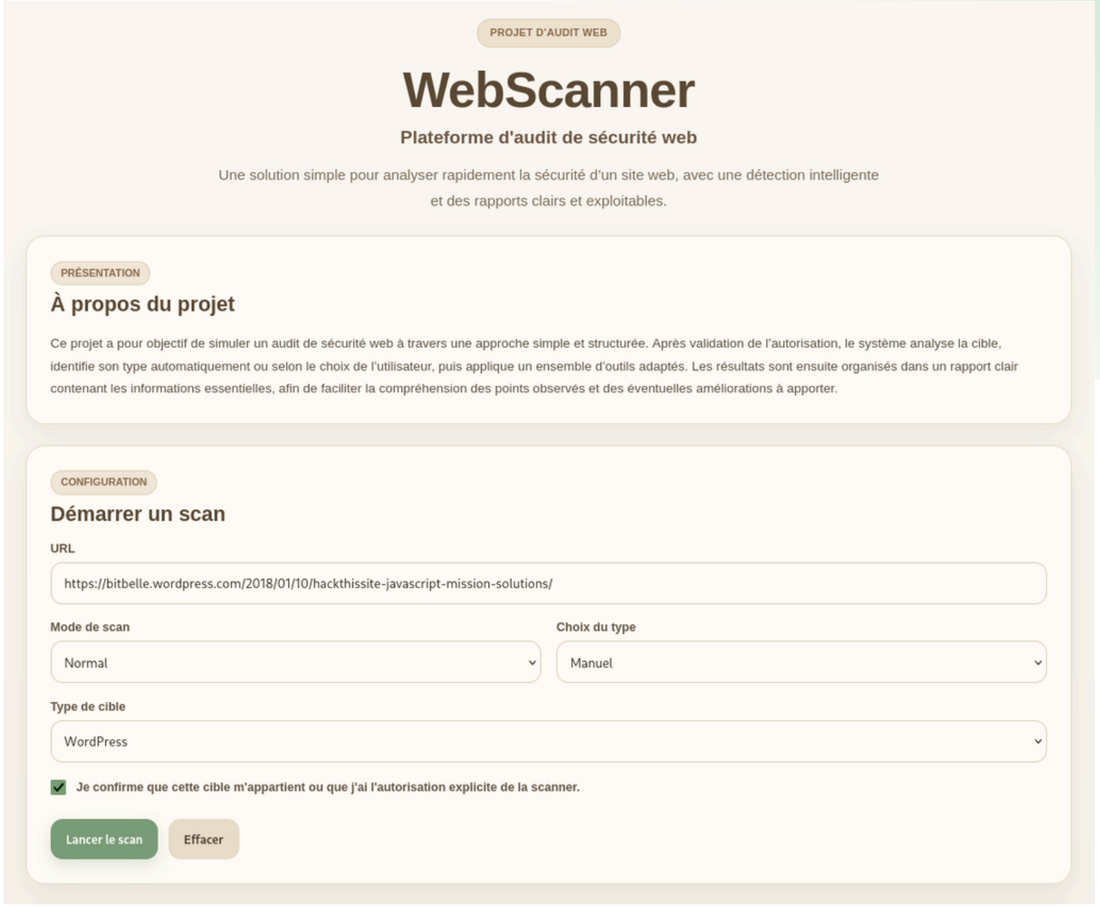
- La cybersécurité est devenue essentielle pour les entreprises
- Les attaques web sont de plus en plus fréquentes
- Les audits de sécurité sont souvent complexes

Problématique

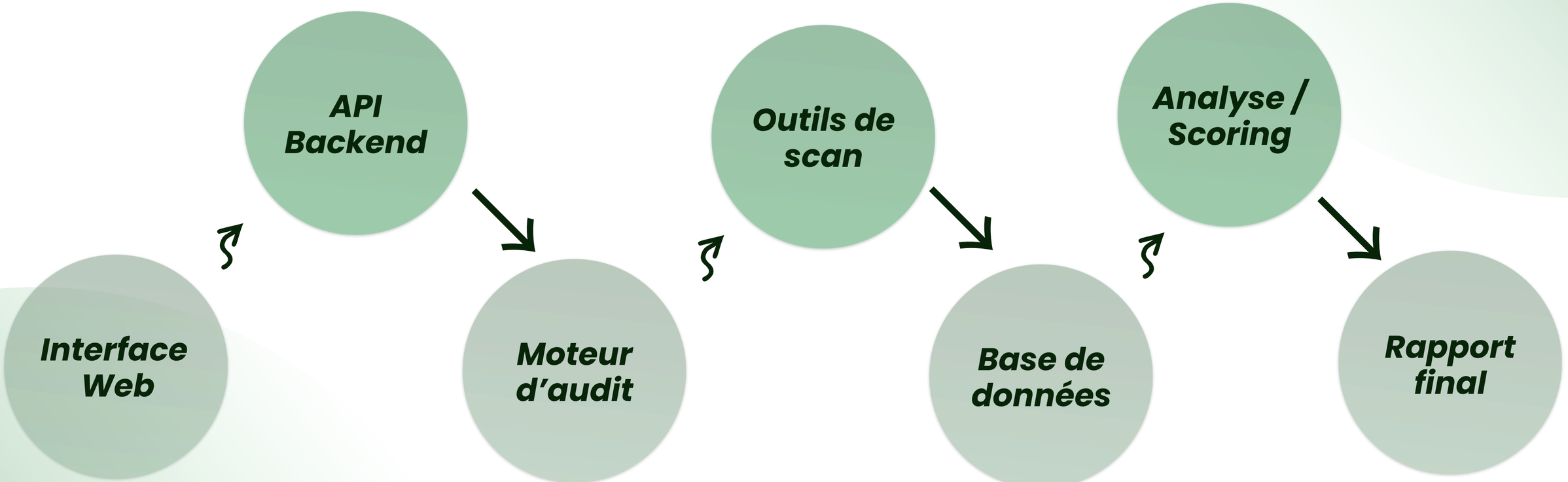
- Difficulté à choisir les bons outils de sécurité
- Manque de centralisation des résultats
- Résultats techniques difficiles à comprendre
- Processus d’audit long et manuel

Objectifs

- Automatiser le processus d’audit
- Détecter rapidement les vulnérabilités web
- Fournir un rapport clair et structuré
- Rendre l’audit accessible aux non-experts



ARCHITECTURE DE LA PLATEFORME



DÉMARCHE DE RÉALISATION

1- Analyse du besoin

Nous avons identifié le besoin d'automatiser les audits de sécurité afin de simplifier le processus pour les entreprises.

2- Recherche des outils

Nous avons étudié différents outils de cybersécurité afin de choisir les plus pertinents et efficaces.

3- Sélection des outils

Nous avons sélectionné des outils complémentaires permettant de couvrir plusieurs types de vulnérabilités.

4- mplémentation des outils

Nous avons implémenté plusieurs outils de sécurité dans un script afin d'automatiser le processus d'audit.

5- Développement de la plateforme

Nous avons développé une plateforme web permettant à l'utilisateur de lancer les analyses facilement.

6- Tests & validation

Nous avons testé la plateforme afin de vérifier son bon fonctionnement et la fiabilité des résultats.

OUTILS UTILISÉS & RÔLES

Reconnaissance

- Subfinder / Amass : Découverte des sous-domaines
- Nmap : Scan des ports et services actifs
- WhatWeb : Identification des technologies du site

Analyse de surface

- Gobuster / Dirsearch: Découverte des répertoires cachés
- Headers Tool : Analyse des headers HTTP
- API Probe : Vérification des endpoints API

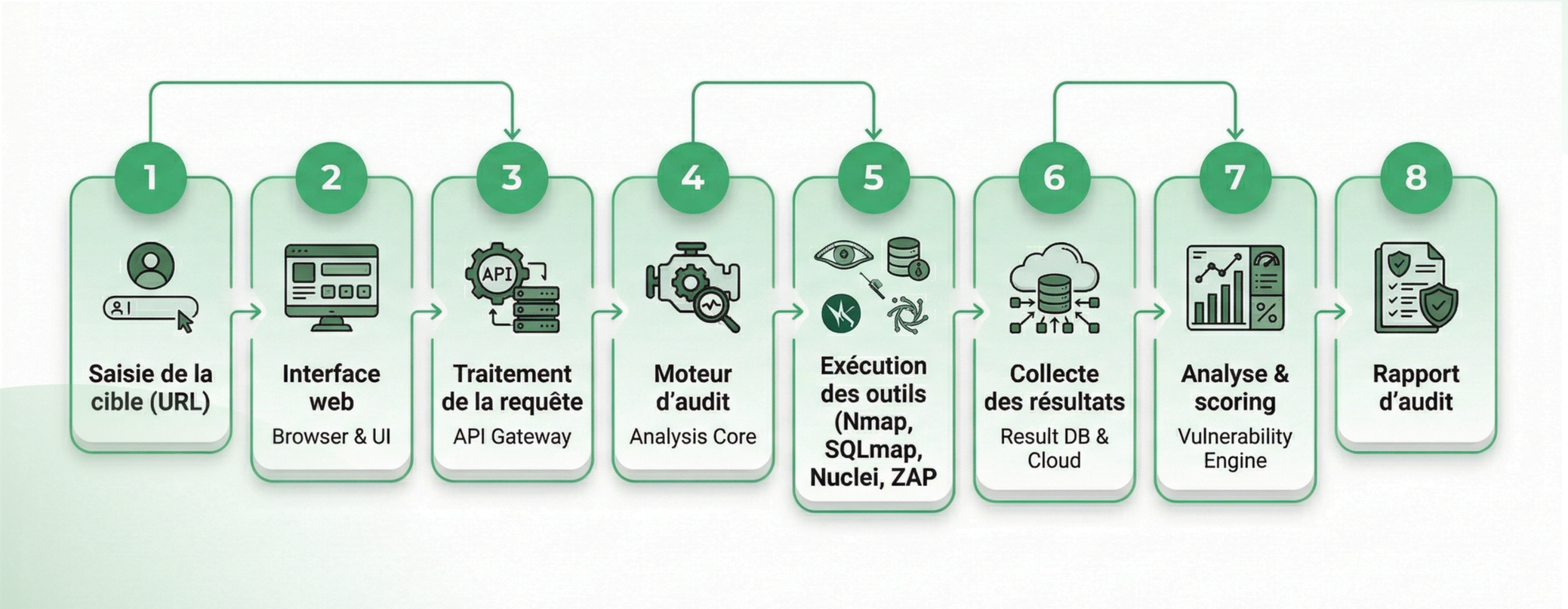
Détection de vulnérabilités

- Nikto : Scan des vulnérabilités web connues
- SQLmap : Détection d'injections SQL
- Dalfox : Détection des failles XSS
- WPScan : Analyse spécifique des sites WordPress
- Nuclei : Scan automatisé basé sur templates

Sécurité & Configuration

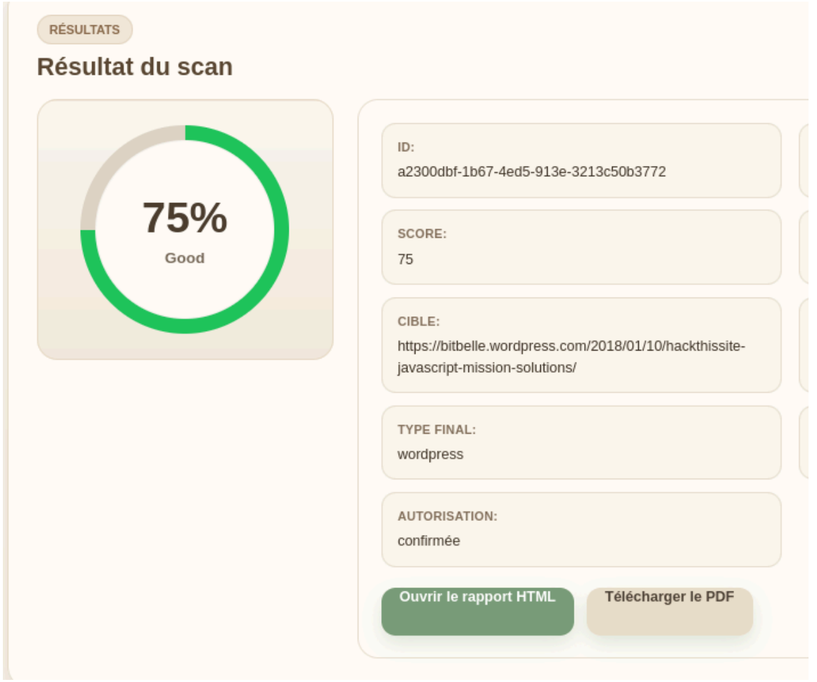
- SSLScan : Analyse de la sécurité SSL/TLS

FONCTIONNEMENT DE LA PLATEFORME



STRUCTURE DU RAPPORT D'AUDIT

- Résumé exécutif → Présentation globale des résultats pour une lecture rapide
- Informations sur la cible → URL / IP analysée et contexte du scan
- Niveau de criticité → Classification (High / Medium / Low) pour prioriser les risques
- Vulnérabilités détectées → Liste des failles identifiées avec description
- Détails techniques → Informations précises issues des outils (preuves)
- Recommandations → Solutions proposées pour corriger chaque vulnérabilité



EXEMPLE DE RAPPORT

Rapport d'audit de sécurité

Rapport automatisé généré par WebScanner.

Cible	https://bitbelle.wordpress.com/2018/01/10/hackthissite-javascript-mission-solutions/
Mode de scan	normal
Sélection du type	manual
Type final	wordpress
Autorisation	Oui
Statut	finished
Début	2026-03-27 21:10:06
Fin	2026-03-27 21:15:19
Score	75% (Good)

Résumé exécutif

Le scan présente un score global de **75%** (niveau **Good**). Aucune vulnérabilité critique ou élevée n'a été détectée. Les constats relevés concernent principalement le durcissement de la configuration de sécurité.

Niveau	Nombre
Critique	0
Élevée	0
Moyenne	0
Faible	6
Info	5

Périmètre et méthodologie

L'audit automatique comprend une phase de fingerprinting, suivie de contrôles adaptés au type de cible détecté ou sélectionné manuellement. Les résultats doivent être interprétés comme une aide au diagnostic et au durcissement, et non comme un audit manuel exhaustif.

Constats détaillés

1. Header manquant: Content-Security-Policy [Faible] - headers

Description : Aucune politique Content-Security-Policy n'a été détectée. Le contrôle des ressources côté navigateur reste donc limité.

Preuve : Server: nginx Date: Fri, 27 Mar 2026 21:10:19 GMT Content-Type: text/html; charset=UTF-8 Transfer-Encoding: chunked Connection: keep-alive Vary: Accept-Encoding, accept, content-type, cookie X-hacker: Want root? Visit join.a8c.com/hacker and mention this header. Host-Header: WordPress.com

Impact : Cette anomalie a un impact limité mais doit être corrigée dans le cadre du durcissement de sécurité.

Recommandation : Définir une politique Content-Security-Policy adaptée afin de mieux contrôler les ressources chargées par le navigateur.

11. Analyse TLS/SSL [Info] - sslscan

Description : Version: 2.1.5 OpenSSL 3.5.4 30 Sep 2025 Connected to 192.0.78.12 Testing SSL server bitbelle.wordpress.com on port 443 using SNI name bitbelle.wordpress.com SSL/TLS Protocols: SSLv2 disabled SSLv3 disabled TLSv1.0 disabled TLSv1.1 disabled TLSv1.2 enabled TLSv1.3 enabled TLS Fallback SCSV: Server supports TLS Fallback SCSV TLS renegotiation: Session renegotiation not supported TLS Compression: Compression disabled Heartbleed: TLSv1.3 not vulnerable to ...

Preuve : Version: 2.1.5 OpenSSL 3.5.4 30 Sep 2025 Connected to 192.0.78.12 Testing SSL server bitbelle.wordpress.com on port 443 using SNI name bitbelle.wordpress.com SSL/TLS Protocols: SSLv2 disabled SSLv3 disabled TLSv1.0 disabled

Impact : Ce résultat est informatif et aide à mieux comprendre l'exposition technique de la cible.

Recommandation : Revoir la configuration TLS/SSL et désactiver les protocoles ou suites cryptographiques faibles ou inutiles.

Recommandations générales

- Priorité 1 : compléter les en-têtes de sécurité HTTP manquants.
- Priorité 2 : renforcer la configuration TLS/SSL et supprimer les protocoles ou options faibles.
- Priorité 3 : réduire l'exposition des services réseau strictement au nécessaire.
- Priorité 4 : limiter la divulgation d'informations techniques sur la cible.
- Priorité 5 : relancer un scan de validation après correction afin de confirmer l'amélioration.

Conclusion

La cible auditée présente un niveau de sécurité global satisfaisant (75% – Good). Les améliorations recommandées relèvent principalement du durcissement, de la réduction de la surface d'exposition et de la validation après correction.

SYSTÈME DE SCORING

1- Origine de la sévérité

- La gravité des vulnérabilités est fournie par les outils de sécurité
- Chaque outil analyse et attribue un niveau (Critical, High, Medium…)
- Basé sur des standards comme CVSS

2- Calcul du score

- Score initial = 100
- Chaque vulnérabilité réduit le score
- Calcul basé sur :
- Niveau de gravité
- Poids de l'outil utilisé

3- Classification finale

- 90+ : Excellent
- 75+ : Good
- 50+ : Medium
- 25+ : Poor
- <25 : Critical

POINTS FORTS & LIMITES

Points forts

- Automatisation complète du processus de scan
- Intégration de plusieurs outils de sécurité
- Analyse rapide et centralisée des résultats
- Génération automatique de rapports exploitables
- Interface simple et accessible pour l'utilisateur

Limites

- Dépendance aux outils externes utilisés
- Possibilité de faux positifs dans les résultats
- Temps de scan variable selon la cible
- Analyse limitée aux vulnérabilités connues
- Nécessite des améliorations pour une précision optimale

EXEMPLE D'AUDIT

Dans cette partie, nous allons démontrer le fonctionnement de notre plateforme en temps réel.

Nous allons lancer un scan sur une cible et analyser les résultats générés automatiquement.

Cela permet de visualiser concrètement les capacités de notre solution.



SAÉ 4.CYBER.01

MERCI POUR VOTRE ÉCOUTE